

MANAGEMENT INFORMATION SYSTEM

Unit-1: Securing the Business on Internet & CRM

Comprehensive Study Notes

1. SECURITY POLICY, PROCEDURES AND PRACTICES

1.1 Introduction to E-Commerce Security

Definition: E-commerce security refers to the measures taken to protect electronic transactions, customer data, and business information from unauthorized access, theft, damage, or disruption during online commercial activities.

Why Security is Critical for E-Commerce

Reason	Description
Customer Trust	Customers will not transact if they fear fraud
Financial Loss	Breaches lead to direct monetary loss
Reputation Damage	Security incidents destroy brand credibility
Legal Liability	Non-compliance leads to penalties and lawsuits
Business Continuity	Security ensures uninterrupted operations
Competitive Advantage	Strong security differentiates from competitors

1.2 Security Objectives (CIA Triad)

[CIA Triad Diagram: Confidentiality - Integrity - Availability]

A. Confidentiality

Definition: Ensuring that information is accessible only to those authorized to access it.

Key Aspects:

- Data should be readable only by intended recipients
- Sensitive information must be protected from unauthorized viewing
- Applies to data in transit, at rest, and in use

Techniques:

Technique	Description
Encryption	Converting data into unreadable format using algorithms
Access Controls	Restricting who can view certain information
Authentication	Verifying user identity before granting access
Data Masking	Hiding sensitive parts of data

B. Integrity

Definition: Ensuring that information is accurate, complete, and has not been altered or tampered with.

Key Aspects:

- Data cannot be modified without detection
- Transaction information must be accurate
- Messages must be authentic and unchanged

Techniques:

Technique	Description
Hashing	Creating a unique digital fingerprint of data
Digital Signatures	Cryptographic proof of document authenticity
Checksums	Verification of data integrity
Audit Trails	Recording all changes to data

C. Availability

Definition: Ensuring that information and services are accessible to authorized users when needed.

Key Aspects:

- 24x7 availability for e-commerce operations
- Quick recovery from failures
- Protection from denial-of-service attacks

Techniques:

Technique	Description
Redundancy	Backup systems and servers
Disaster Recovery	Plans for system restoration
Load Balancing	Distributing traffic across servers
Firewalls	Protecting against attacks
Intrusion Detection	Monitoring for threats

1.3 Security Policy

Definition: A security policy is a formal document that outlines the rules, procedures, and guidelines for protecting an organization's information assets.

Components of a Security Policy

[Security Policy Components Flowchart]

Sample Security Policy Structure

Section	Description
Policy Statement	High-level overview and objectives
Scope	Who and what the policy applies to
Definitions	Key terms and concepts
Responsibilities	Who is responsible for security
Access Control	How access is granted and revoked
Data Protection	Data classification and handling
Password Management	Password creation and maintenance
Network Security	Firewalls, VPN, wireless security
Physical Security	Building and hardware protection
Incident Response	What to do when breach occurs
Compliance	Regulatory requirements
Enforcement	Consequences of violations
Review	How often policy is updated

1.4 Security Procedures

Definition: Procedures are the step-by-step instructions that implement the security policy.

Types of Security Procedures

A. Administrative Procedures:

- User account creation/deletion
- Access request and approval process
- Security awareness training
- Security incident reporting
- Background checks for employees

B. Technical Procedures:

Procedure	Description
Backup Procedures	Regular data backup schedule and testing
Patch Management	Applying security updates to systems
Antivirus Updates	Regular virus definition updates
Log Review	Periodic review of system logs
Vulnerability Scanning	Regular security assessments
Password Change	Scheduled password updates

C. Physical Procedures:

- Building access control
- Server room security
- Hardware disposal methods
- Visitor logging

1.5 Security Practices

A. Best Security Practices for E-Commerce:

Practice	Description
PCI DSS Compliance	Meet Payment Card Industry Data Security Standards
Secure Sockets Layer (SSL)	Use HTTPS for all transactions
Two-Factor Authentication	Require additional verification beyond passwords
Regular Security Audits	Assess vulnerabilities periodically
Employee Training	Educate staff on security risks
Data Encryption	Encrypt sensitive data at rest and in transit
Firewall Configuration	Protect network perimeter
Intrusion Detection Systems	Monitor for suspicious activity
Incident Response Plan	Preparedness for security events
Third-Party Security	Vet vendors and partners

B. Common Security Mistakes to Avoid:

Mistake	Why It's Dangerous	Solution
Weak Passwords	Easy to guess or crack	Strong password policies
Outdated Software	Known vulnerabilities exploited	Regular updates
No Encryption	Data intercepted during transmission	SSL/TLS encryption
Single Point of Failure	One breach compromises everything	Defense in depth
Ignoring Logs	Attacks go undetected	Regular log review
No Backup Strategy	Data loss leads to business failure	Automated backups
Too Much Trust	Insider threats exploited	Principle of least privilege

2. TRANSACTION SECURITY

2.1 Introduction to Transaction Security

Definition: Transaction security refers to the measures taken to ensure that electronic transactions are safe, confidential, and legally binding.

[Transaction Security Key Aspects Flowchart]

2.2 Authentication Methods

Definition: The process of verifying the identity of a user or entity.

Types of Authentication (Three Factors)

[Three Factors of Authentication: Knowledge - Possession - Inherence]

Authentication Type	Examples	Security Level
Single-Factor	Password only	Low
Two-Factor (2FA)	Password + OTP	Medium
Multi-Factor (MFA)	Password + OTP + Biometric	High

Passwords and PINs

Characteristics of Strong Passwords:

- Minimum 8-12 characters
- Combination of upper/lowercase letters

- Include numbers and special characters
- Not based on personal information
- Changed regularly

Common Password Mistakes to Avoid:

Mistake	Example
Using common words	"password", "admin"
Using personal info	Birthdate, pet name
Same password everywhere	One breach compromises all
Writing down passwords	Sticky notes on monitor
Sharing passwords	Giving to colleagues
Using keyboard patterns	"qwerty123"

Biometric Authentication

Biometric Type	Description	Advantages	Disadvantages
Fingerprint	Unique fingerprint patterns	Fast, reliable	Can be spoofed
Face Recognition	Facial features	Contactless	Lighting affects accuracy
Iris Recognition	Eye patterns	Highly accurate	Expensive
Voice Recognition	Voice patterns	Natural, easy	Background noise affects
Palm/Finger Vein	Vascular patterns	Very secure	Specialized hardware

2.3 Authorization

Definition: The process of determining what resources an authenticated user is allowed to access.

Mechanism	Description	Example
Role-Based (RBAC)	Access based on user role	Admin, Manager, User

Rule-Based Access	Access based on rules	IP-based restrictions
Attribute-Based Access	Access based on attributes	Location, time, device
Mandatory Access	System-defined access	Military classification
Discretionary Access	Owner-defined access	File permissions

3. ENCRYPTION & DIGITAL SECURITY

3.1 Encryption

Definition: The process of converting plain text into cipher text that is unreadable without the correct decryption key.

[Encryption / Decryption Process Flowchart: Plain Text → Encryption → Cipher Text → Decryption → Plain Text]

A. Symmetric Encryption

Aspect	Description
Definition	Same key used for encryption and decryption
Key Sharing	Both parties must share the key
Speed	Very fast
Key Management	Challenging (key distribution)
Examples	AES, DES, 3DES, Blowfish

Advantages: Fast processing, good for large data volumes

Disadvantages: Key distribution problem, everyone needs the same key

B. Asymmetric Encryption (Public Key)

Aspect	Description
Definition	Different keys for encryption (public) and decryption (private)
Key Sharing	Public key can be shared widely

Speed	Slower than symmetric
Key Management	Easier (public keys distributed)
Examples	RSA, ECC, Diffie-Hellman

Advantages: Secure key exchange, digital signatures possible, no key sharing required

Disadvantages: Slower processing, more computational overhead

3.2 Digital Signatures

Definition: A digital signature is a mathematical scheme for verifying the authenticity and integrity of a digital message.

[Digital Signature Process: Sender → Hash → Encrypt with Private Key → Digital Signature → Receiver → Decrypt with Public Key → Verify Hash]

Feature	Description
Authenticity	Confirms identity of sender
Integrity	Confirms document not altered
Non-Repudiation	Sender cannot deny sending
Legal Validity	Recognized under law

Applications in E-Commerce: Contract signing, invoice approval, order confirmation, payment authorization

3.3 Digital Certificates

Definition: A digital certificate is an electronic document that uses a digital signature to bind a public key with an identity.

Component	Description
Subject	Owner's name, organization, email

Public Key	Owner's public key
Issuer	Certificate Authority (CA)
Serial Number	Unique identifier
Validity Period	Start and end dates
Digital Signature	CA's signature
Certificate Version	X.509 version

[Digital Certificate Verification Process]

Types of Digital Certificates:

Type	Description	Use Case
SSL/TLS Certificate	Secures website communication	HTTPS websites
Code Signing Certificate	Verifies software authenticity	Application installation
Email Certificate	Secures email communication	S/MIME email
Client Certificate	Identifies individual users	Two-factor authentication
Device Certificate	Identifies devices	IoT authentication

3.4 SSL/TLS Protocol

Definition: Cryptographic protocols that provide secure communication over a computer network.

[SSL/TLS Handshake: Client ↔ Server - Certificate Exchange - Key Agreement - Secure Connection Established]

SSL/TLS in E-Commerce:

- Indicated by "https://" in URL

- Padlock icon in browser
- Encrypts all data between browser and server
- Essential for payment transactions

Benefit	Description
Data Encryption	All data encrypted during transmission
Authentication	Server identity verified
Data Integrity	Data cannot be altered in transit
Trust Indicator	Visual cues build customer trust
SEO Benefit	Google prefers HTTPS sites

3.5 Secure Electronic Transaction (SET)

Definition: SET was a communications protocol standard for securing credit card transactions over networks.

Participant	Role
Cardholder	Customer making purchase
Merchant	Business selling product/service
Issuer	Cardholder's bank
Acquirer	Merchant's bank
Payment Gateway	Processes transaction

SET vs SSL:

Aspect	SET	SSL/TLS
Security Level	Very High	High
Implementation	Complex	Simple
Adoption	Limited	Widespread

Cost	Expensive	Affordable
Infrastructure	Requires special software	Built into browsers

4. SECURITY THREATS

Categories of Security Threats:

Malware

Type	Description
Virus	Malicious code that replicates by attaching to other programs
Worm	Self-replicating malware that spreads without user action
Trojan	Disguised as legitimate software to trick users
Ransomware	Encrypts files and demands payment for decryption

Hacking Attacks

Attack	Description
Phishing	Fraudulent attempts to obtain sensitive information via deceptive emails/websites
Spoofing	Faking identity (email, IP, DNS) to gain unauthorized access
DoS/DDoS	Overwhelming a system with traffic to make it unavailable
SQL Injection	Injecting malicious SQL queries to manipulate databases
XSS (Cross-Site Scripting)	Injecting malicious scripts into web pages viewed by others
MITM (Man-in-the-Middle)	Intercepting communication between two parties

5. SECURITY TECHNOLOGIES

Technology	Description
Symmetric Encryption (AES)	Same key encrypts and decrypts; fast, used for bulk data
Asymmetric Encryption (RSA)	Public/private key pair; slower, used for key exchange & signatures
Hybrid Encryption	Combines symmetric (for data) and asymmetric (for key exchange)
Digital Signatures	Cryptographic proof of authenticity and integrity
Digital Certificates	Bind public key to identity, issued by CA
PKI (Public Key Infrastructure)	Framework for managing public-key encryption and certificates
SSL/TLS	Secure communication protocol for internet transactions
Firewalls	Filter incoming/outgoing traffic based on security rules
IDS/IPS	Intrusion Detection/Prevention Systems monitor and block threats
VPN (Virtual Private Network)	Creates encrypted tunnel for secure remote access
2FA / MFA	Two-factor / multi-factor authentication for enhanced security
Biometrics	Unique biological traits for identity verification

6. CUSTOMER RELATIONSHIP MANAGEMENT (CRM)

6.1 Introduction to CRM

Definition: Customer Relationship Management (CRM) is a business strategy that uses technology and processes to manage and analyze customer interactions and data throughout the customer lifecycle, with the goal of improving business relationships and customer retention.

Key Objectives of CRM:

- Acquire new customers
- Retain existing customers
- Grow customer lifetime value
- Improve customer satisfaction
- Reduce marketing costs

[CRM Strategy Flowchart]

6.2 Benefits of CRM

Benefit	Description
Improved Customer Experience	Personalized, seamless interactions
Increased Customer Retention	Better understanding of customer needs
Higher Revenue	More effective marketing and sales
Cost Reduction	Automated processes, lower overhead
Better Decision Making	Data-driven insights

Competitive Advantage	Superior customer relationships
Customer Loyalty	Stronger emotional connection
Cross-Selling/Up-Selling	Identify sales opportunities

6.3 Types of CRM

A. Operational CRM

Focuses on automating customer-facing processes: marketing automation, sales automation, service automation.

B. Analytical CRM

Focuses on analyzing customer data for insights: customer segmentation, churn analysis, profitability analysis.

C. Collaborative CRM

Focuses on sharing customer information across departments: communication management, channel integration.

6.4 CRM Cycle

[CRM Cycle: Acquire → Enhance → Retain → Win Back]

1. **Acquire:** Attract new customers through marketing
2. **Enhance:** Deepen relationship through cross-selling/up-selling
3. **Retain:** Maintain satisfaction and loyalty
4. **Win Back:** Re-engage lost customers

6.5 E-CRM (Electronic CRM)

Definition: E-CRM is the application of internet and web technologies to customer relationship management using digital channels.

E-CRM vs Traditional CRM:

Aspect	Traditional CRM	E-CRM
Channel	Phone, mail, in-person	Web, email, social media, mobile
Interaction Type	Company-initiated	Customer-initiated
Data Collection	Limited	Massive (Web analytics)
Response Time	Hours/Days	Real-time
Personalization	Limited	Highly personalized
Cost	High	Lower
Customer Reach	Limited	Global

E-CRM Applications:

- **Marketing Automation:** Email campaigns, lead generation, segmentation, personalization
- **Sales Automation:** Contact management, lead tracking, opportunity management, quote generation
- **Service Automation:** Help desk, live chat, chatbots, knowledge base, feedback management

7. E-CRM IN INDIA & GLOBAL SCENARIO

7.1 Indian E-CRM Market

Trend	Description
Digital-First Approach	Businesses prioritizing digital channels
Omni-Channel Engagement	Consistent experience across channels
Personalization	Customized experiences and recommendations
Data Analytics	Leveraging customer data for insights
AI Integration	Chatbots, predictive analytics
Cloud CRM	Scalable solutions (Salesforce, Zoho, HubSpot)

7.2 CRM Utility in Indian Sectors

E-Commerce (Flipkart, Amazon, Myntra)

- Personalized product recommendations
- Abandoned cart recovery
- Customer loyalty programs
- Post-purchase engagement

Banking/Financial Services

- Personalized banking experiences
- Fraud detection
- Customer segmentation
- Targeted offers

Telecommunications (Jio, Airtel, Vi)

- Customer onboarding
- Service management (bill payments, recharges)
- 24x7 customer support
- Churn management

Travel & Hospitality (MakeMyTrip, Oyo)

- Personalized recommendations
- Loyalty programs
- Trip assistance
- Reviews and ratings

7.3 Global E-CRM Trends

Trend	Description
AI and Machine Learning	Predictive analytics, chatbots
Social CRM	Integrating social media
Voice CRM	Voice interfaces
Mobile-First	Mobile-optimized CRM
Blockchain	Secure data management
Personalization at Scale	Hyper-personalization

7.4 Security & CRM - Integrated View

Security Requirements for CRM:

- **Data Privacy:** Protect personal information
- **Access Control:** Restrict who can view data
- **Encryption:** Encrypt sensitive data
- **Audit Trails:** Track data access
- **Compliance:** Follow regulations (GDPR, DPDP)

- **Backup:** Regular data backup
- **User Authentication:** Secure login systems

Regulatory Compliance in India:

Regulation	Description
DPDP Act (2023)	Digital Personal Data Protection Act
IT Act (2000)	Information Technology Act
IT (Reasonable Security Practices) Rules	Security requirements
PCI DSS	Payment card security
RBI Guidelines	Banking data security

UNIT SUMMARY

Topic	Key Points
Security Policy	CIA Triad (Confidentiality, Integrity, Availability); Formal policy document
Security Procedures	Administrative, Technical, Physical
Security Practices	PCI DSS, SSL, 2FA, Encryption, Training
Authentication	Knowledge, Possession, Inherence; 2FA/MFA
Encryption	Symmetric (AES), Asymmetric (RSA); Digital signatures
Digital Certificates	SSL/TLS certificates; Certificate Authority
Transaction Security	SSL/TLS, SET
CRM	Customer Relationship Management strategy
E-CRM	Online CRM using digital channels
E-CRM Types	Operational, Analytical, Collaborative
E-CRM Applications	Marketing, Sales, Service Automation

PRACTICE QUESTIONS

Long Questions (10 marks)

1. Explain the security objectives (CIA Triad) in e-commerce with suitable examples.
2. What are security policies, procedures, and practices? Explain with examples.
3. Discuss the various authentication methods used in e-commerce.
4. Explain encryption and digital signatures with diagrams.
5. What is CRM? Explain E-CRM and its applications.
6. Differentiate between traditional CRM and E-CRM.
7. Discuss the utility of CRM in Indian e-commerce.
8. Explain SSL/TLS protocol and its role in e-commerce security.

Short Notes (5 marks)

1. CIA Triad
2. Digital Signatures and their features
3. Biometric authentication methods
4. Types of malware
5. Firewalls and IDS/IPS
6. PKI and Digital Certificates
7. E-CRM components
8. Security challenges in CRM
9. SET protocol

10. Regulatory compliance for e-commerce in India

KEY DIAGRAMS TO PRACTICE

1. **CIA Triad** - Confidentiality, Integrity, Availability
2. **Security Policy Structure** - Components flow chart
3. **Encryption Process** - Symmetric and Asymmetric
4. **Digital Signature Process** - Sender and Receiver flow
5. **SSL/TLS Handshake** - Client-Server interaction
6. **E-CRM Components** - Operational, Analytical, Collaborative
7. **CRM Utility Diagram** - Acquisition, Retention, Revenue
8. **Authentication Factors** - Knowledge, Possession, Inherence